

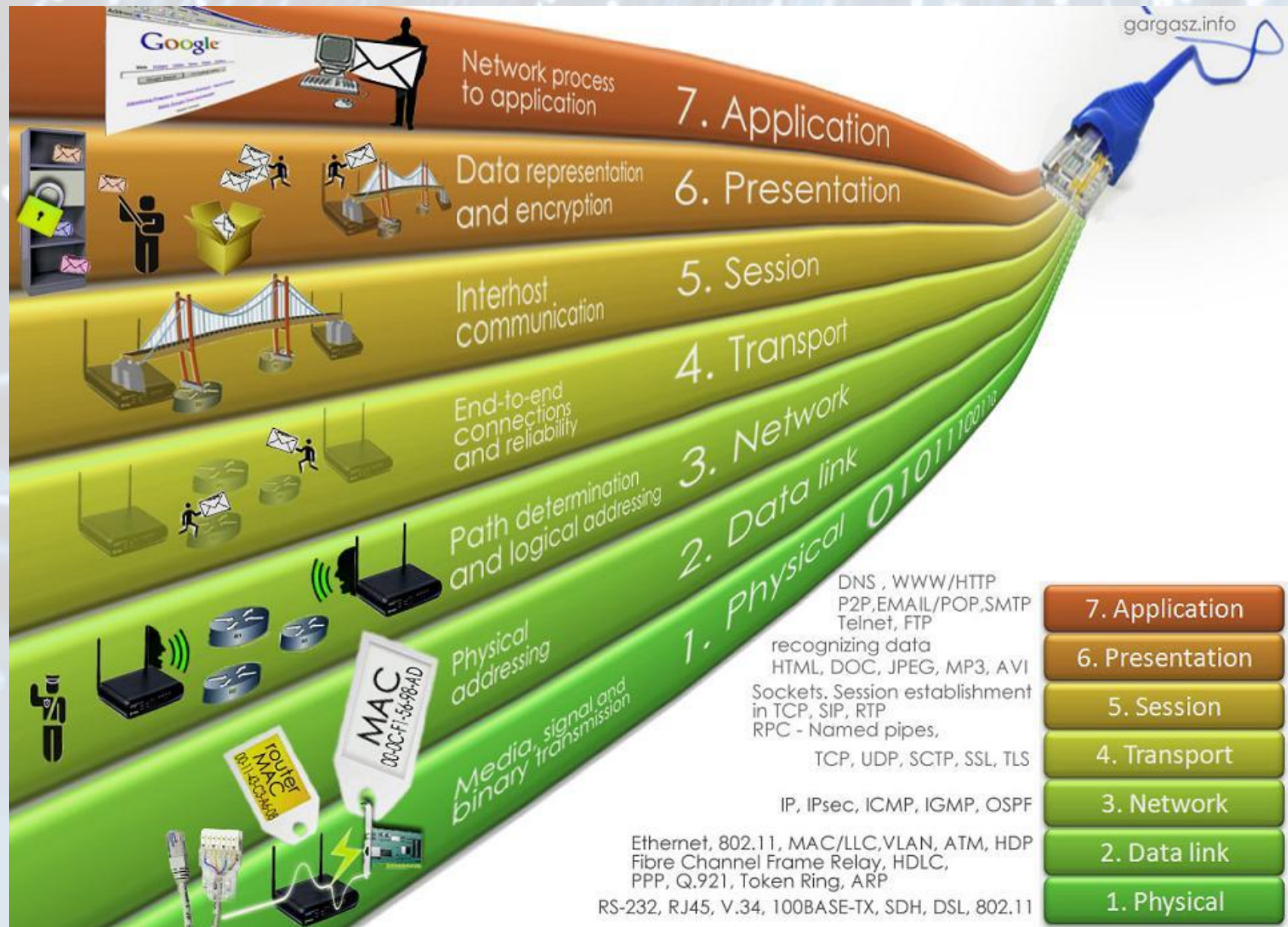


Seguridad en redes

Vulnerabilidad de los servicios en red

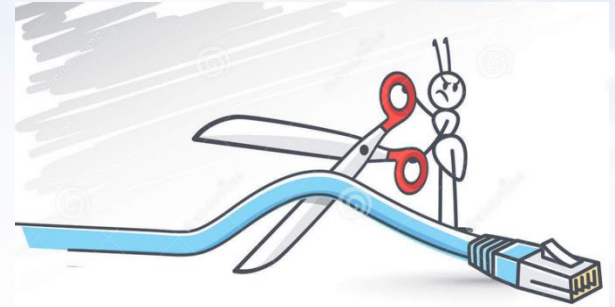
- Las redes de telecomunicación basan su funcionamiento en el **modelo OSI** de interconexión de equipos informáticos.
- Cada nivel del modelo OSI presenta vulnerabilidades que pueden ser explotadas por un atacante y que debemos conocer.





Nivel físico

- Es el responsable de la conexión del equipo informático a la red y se encarga de la transmisión de información a través de ella.
- Las **vulnerabilidades** de este nivel están **relacionadas con el acceso físico no autorizado a los dispositivos de red**.
 - Ejemplo de ataques sobre este nivel son: corte o desconexión de un cable de red o interferencias electromagnéticas ocasionadas por algún dispositivo que impidan el funcionamiento normal de la red.



Nivel de enlace de datos

- Se encarga del direccionamiento físico, acceso al medio, la detección de errores, la distribución ordenada de tramas y del control de flujo.
- Aquí se dan **vulnerabilidades asociadas al medio sobre el que se realiza la conexión**, como el control de acceso y la confidencialidad.
- Algunos ataques son:
 - Escuchas de red, tanto intrusivas en medios cableados (pinchar un cable), como no intrusivas en medios inalámbricos (ataques WEP).
 - Falsificación de direcciones MAC para evitar restricciones de acceso basadas en el filtrado MAC.
 - Envenenamiento ARP.

Nivel de red

- Proporciona conectividad entre equipos, permitiendo que la información llegue desde el origen al destino aunque se encuentren en redes diferentes. Esto es posible gracias a la información de cabecera que contienen todos los paquetes IP y a la utilización de elementos que permiten la interconexión de redes como routers.
- Este nivel **presenta vulnerabilidades asociadas a la integridad y confidencialidad de la información.**
- Se pueden dar los siguientes ataques:
 - Suplantación de mensajes (IP spoofing): El atacante envía paquetes utilizando una dirección origen diferente, modificándola por una dirección IP falsa o de otro equipo legítimo de la red.
 - Denegación de servicio.

Nivel de transporte

- Este nivel proporciona un servicio de transporte desde la máquina origen a la de destino, independizándolo del hardware de red utilizado. Los protocolos más conocidos son TCP y UDP, que transmiten información sobre paquetes IP.
- **Las vulnerabilidades de este nivel se asocian a la autenticación, integridad y confidencialidad de la información.**
- Se pueden dar los siguientes ataques:
 - Denegación de servicio.
 - Ataques contra el establecimiento de sesiones TCP: interceptación de sesiones TCP establecidas para redirigirlas a otros equipos
 - Ataques de reconocimiento: realizar barridos de puertos TCP/UDP contra un equipo y de esta forma averiguar qué aplicaciones y puertos tiene en escucha para poder realizar un ataque posterior a un determinado servicio.

Niveles de sesión, presentación y aplicación

- Los niveles superiores son los más cercanos al usuario.
- Estos niveles desconocen la forma en la que se comunican los equipos y la ruta establecida y se encargan de definir los protocolos de aplicación que utilizan las aplicaciones finales para intercambiar datos.
- No obstante, estos niveles presentan muchas **vulnerabilidades que afectan a la confidencialidad, integridad, disponibilidad, no repudio o autenticación, que pueden ser aprovechadas por los atacantes.**

Niveles de sesión, presentación y aplicación

- Tipos de ataques:
 - **Ataques sobre la confidencialidad**
 - **Suplantación del servicio de nombres de dominio:** En este tipo de ataque se suplanta al servidor DNS, suministrando una dirección IP falsa
 - **Agotamiento de direcciones IP:** consiste en enviar una gran cantidad de peticiones al servidor DHCP
 - **Inyección SQL:** aprovecha vulnerabilidades en el diseño de una aplicación web para ejecutar código SQL no esperado sobre una base de datos
 - **Escalada de directorios:** acceder a directorios para los que no se debería tener acceso
 - **XSS (Cross Site Scripting):** código malicioso en las páginas web visitadas.
 - **Desbordamiento de buffer:** consiste en aprovechar algún fallo de diseño de una aplicación con el objetivo de ejecutar código malicioso en el ordenador de la víctima.

Ataques de DoS

- Consisten en distintas actuaciones que persiguen colapsar determinados equipos o redes informáticas, para impedir que puedan ofrecer sus servicios a sus clientes y usuarios.
- Posibilidades:
 - Ejecutar actividades que produzcan un elevado consumo de los recursos de las máquinas afectadas: procesador, memoria, HD, provocando una caída en su rendimiento.
 - Provocar el colapso de redes mediante la generación de grandes cantidades de tráfico
 - Transmisión de paquetes de datos malformados o que incumplan las reglas de un protocolo para provocar la caída de un equipo que no se encuentre preparado para recibir este tipo de tráfico
 - Sabotajes mediante routers “maliciosos” que se encarguen de proporcionar información falsa sobre tablas de enrutamiento que impidan el acceso a ciertas máquinas de la red.

- Activación de programas malware que se repliquen dentro de un sistema informático, consumiendo la memoria y la capacidad de proceso hasta detener el equipo.
- Envío masivo de miles de mensajes de correo electrónico provocando la sobrecarga del servidor de correo y redes afectadas.
- Ataque reflector, que pretende generar un intercambio ininterrumpido de tráfico entre dos o más equipos para disminuir su rendimiento o bloquearlos.
- Incumplimiento de las reglas de un protocolo. Para ello se suelen utilizar protocolos no orientados a conexión como UDP o ICMP o bien TCP sin llegar a establecer una conexión completa con el equipo atacado. Ejemplos: ping de la muerte, land attack, supernuke, teardrop, SYN flood,

Ataques de denegación de servicio en redes

- Seguramente son el ejemplo más conocido de ataque sobre los niveles de red y transporte, también conocidos como ataques TCP/IP.
- Existe una gran variedad de ataques de denegación de servicio, entre los que se encuentran:
 - **Inundación IP** → Consiste en el envío de tráfico masivo para conseguir la degradación de los servicios de la red
 - **Falsificación IP origen**: 2 tipos de ataque:
 - **Broadcast**: Consiste en que se falsea la dirección IP origen del atacante, indicando la dirección de difusión (broadcast) de la red.
 - **Smurf**. El atacante falsea su dirección IP origen, enviando paquetes de difusión haciéndose pasar por la dirección IP de la víctima, quien recibirá las respuestas de todas las estaciones de la red

Ataques de denegación de servicio en redes

- Otros tipos de ataques de denegación de servicio:
 - **Inundación TCP/SYN** → consiste en saturar el tráfico de la red para aprovechar el mecanismo de negociación de tres vías del protocolo TCP. Dicho mecanismo permite que cualquier conexión a Internet "segura" (una que utiliza el protocolo TCP) se realice. Cuando un cliente establece una conexión con un servidor, envía una solicitud SYN; el servidor responde con un paquete SYN/ACK y el cliente valida la conexión con un paquete ACK (reconocimiento). No es posible establecer una conexión TCP hasta haber finalizado estas tres vías. El ataque SYN consiste en enviar una gran cantidad de solicitudes SYN a través de un ordenador con una dirección IP inexistente o no válida. En consecuencia, el equipo de destino no puede recibir un paquete ACK.

Ataques de denegación de servicio en redes

- **Teardrop** → Un "ataque por fragmentación" consiste en saturar el tráfico de la red (denegación de servicio) para aprovechar el principio de fragmentación del protocolo IP.

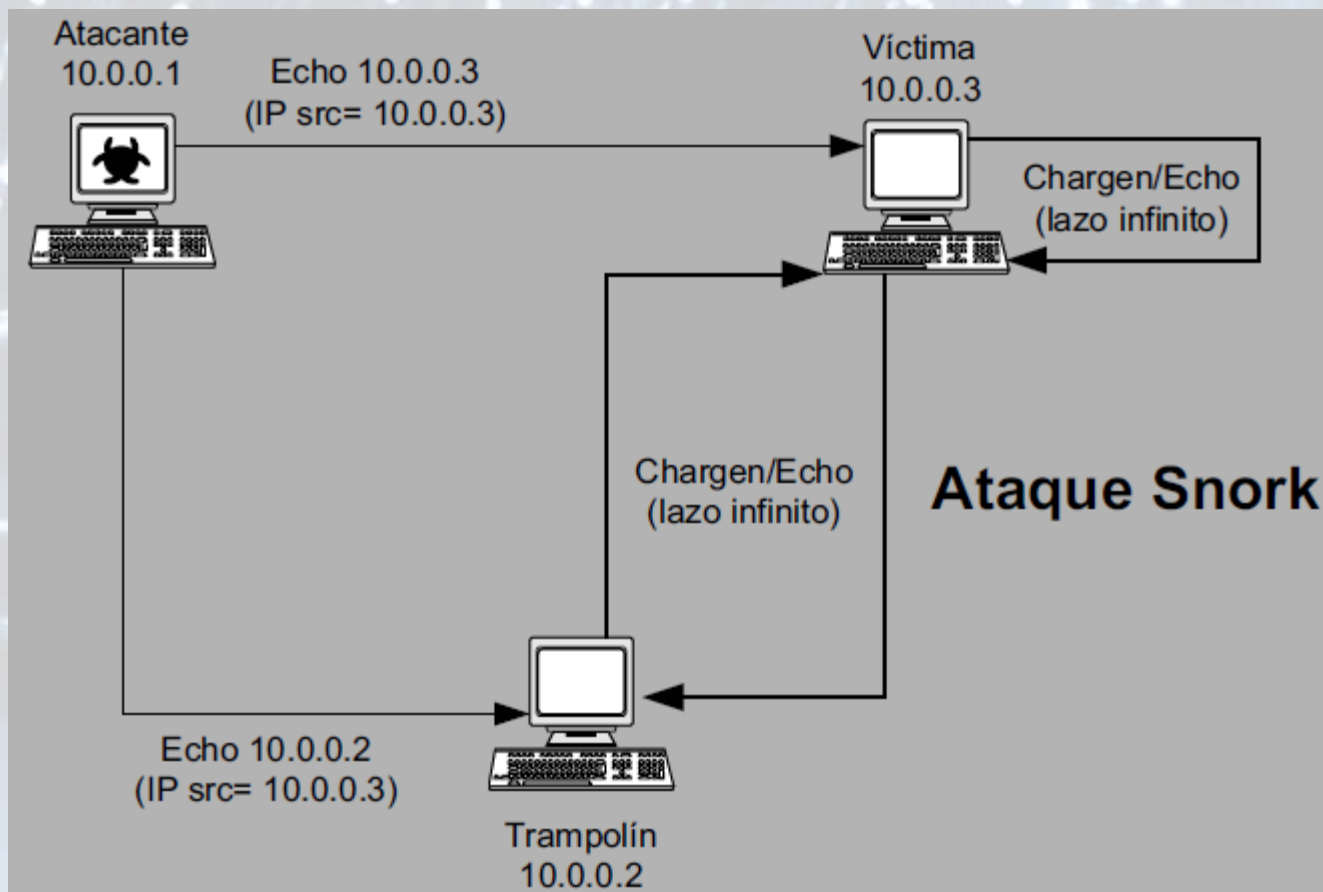
Este protocolo se utiliza para fragmentar paquetes grandes en varios paquetes IP más pequeños. Cada uno de ellos tiene un número de secuencia y un número de identificación común. Cuando recibe datos, el destinatario puede volver a ensamblarlos gracias a los valores de compensación que contienen.

El ataque por fragmentación se basa en introducir información de compensación falsa en los paquetes fragmentados. En consecuencia, durante el reensamblado, quedan fragmentos vacíos o superpuestos que pueden desestabilizar el sistema.

Ataques de denegación de servicio en redes

- **Snork** → El ataque Snork se basa en una utilización malintencionada de dos servicios típicos en sistemas Unix: el servicio CHARGEN (CHARacter GENerator, generador de caracteres) y el servicio ECHO. El primer servicio se limita a responder con una secuencia aleatoria de caracteres a las peticiones que recibe. El segundo servicio, ECHO, se utiliza como sistema de pruebas para verificar el funcionamiento del protocolo IP. Así, esta denegación de servicio se basa en el envío de un datagrama especial al ordenador de destino, que una vez reconocido, enviará una respuesta al equipo de origen.

El ataque Snork consiste en el cruce de los servicios ECHO y CHARGEN, mediante el envío de una petición falsa al servicio CHARGEN, habiendo colocado previamente como dirección de origen la dirección IP de la máquina que hay que atacar (con el puerto del servicio ECHO como puerto de respuesta). De esta forma, se inicia un juego de ping-pong infinito.

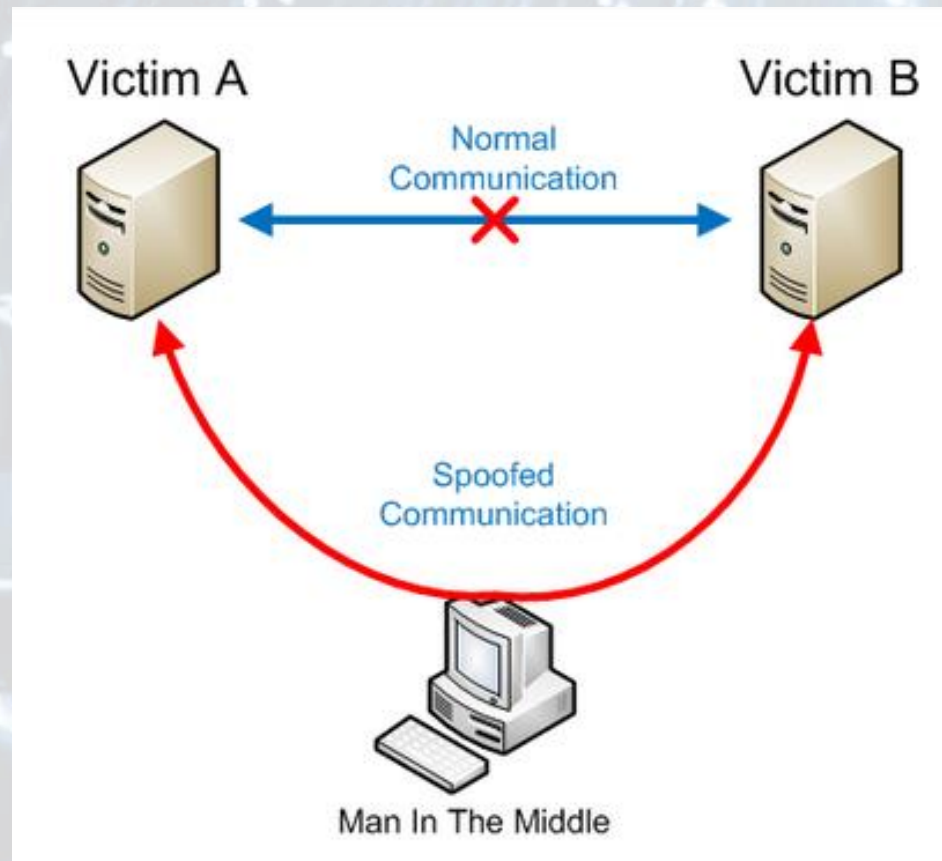


Ataques comunes en redes locales

- Man in the Middle
- Envenenamiento ARP
- Ataques al DHCP
- Ataques a SSL/TLS

Man In the Middle

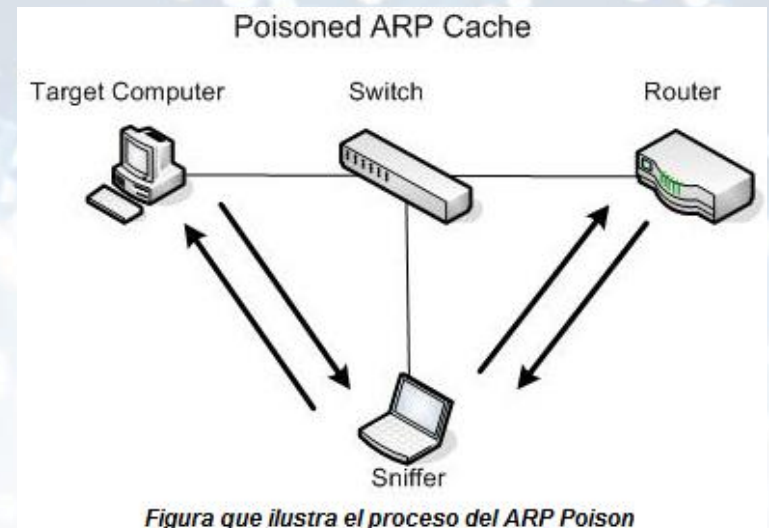
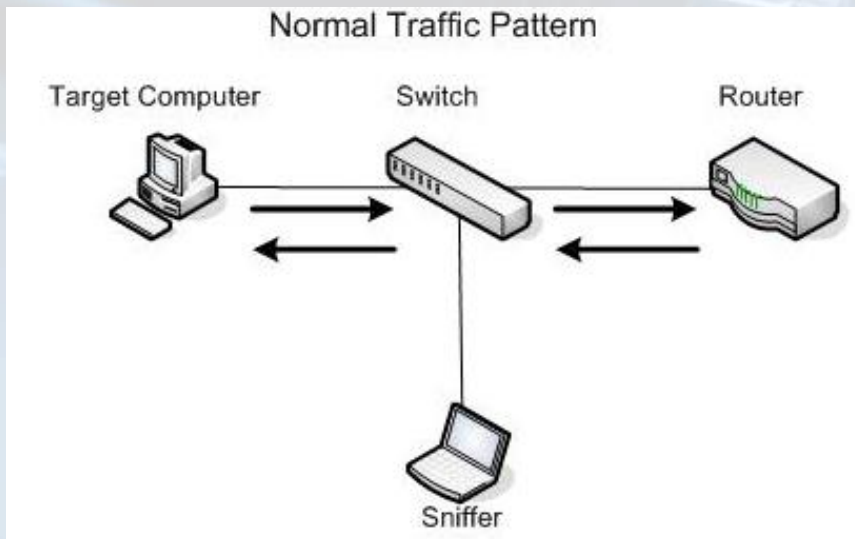
- Los ataques MITM (Man In The Middle) es una clasificación de ataques bajo la que se pueden agrupar las técnicas que permiten que un atacante se introduzca en medio de una comunicación entre dos víctimas, de forma que se puede interceptar, modificar, espiar o destruir la comunicación.
- Es habitual ponerse en el camino entre el router de acceso a Internet y la víctima. De esta forma el atacante tiene acceso a las comunicaciones en ambos sentidos: de la víctima a Internet y de Internet a la víctima.



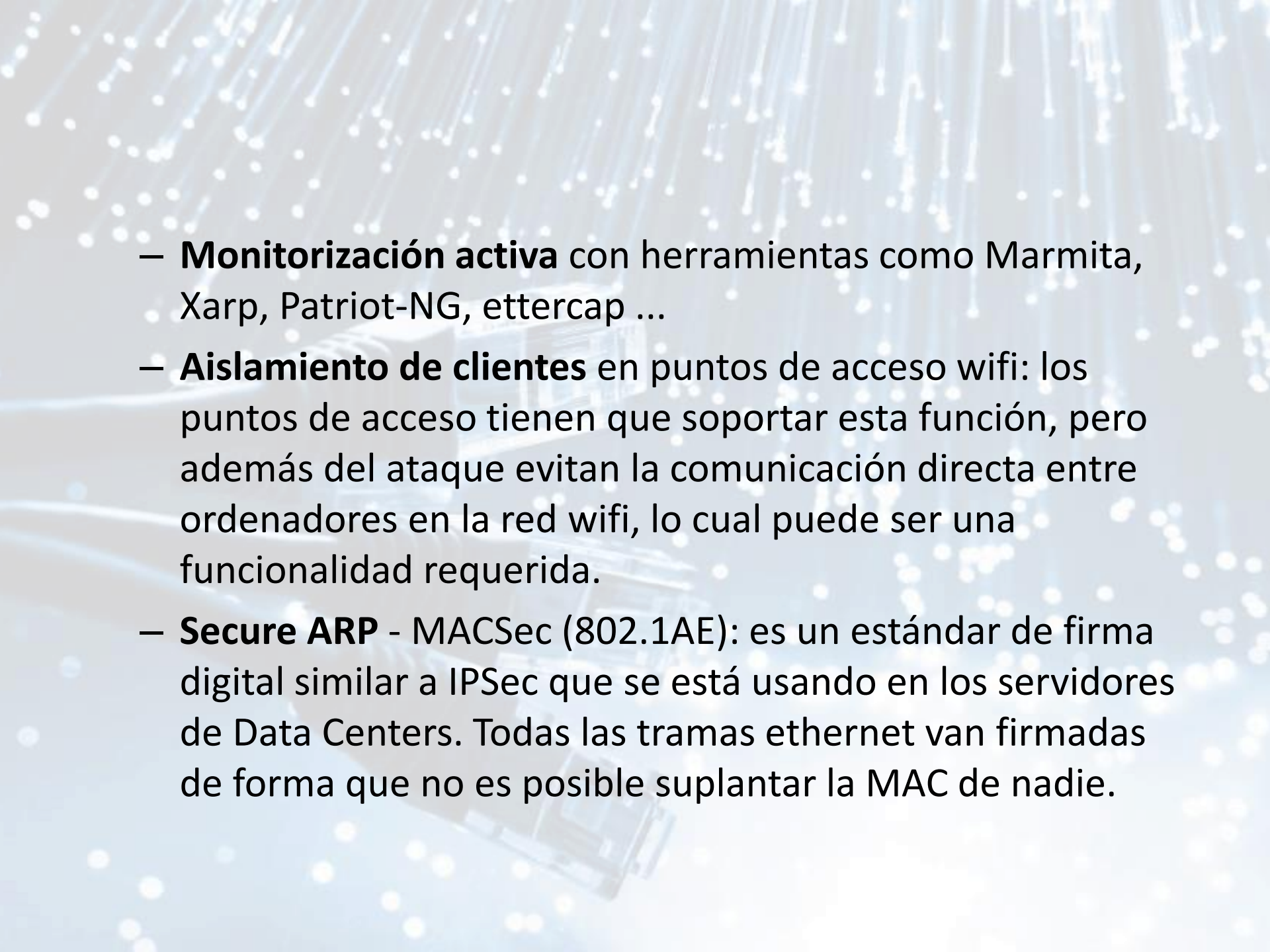
Envenenamiento ARP

- El ARP es un protocolo de IPv4 que permite a un ordenador o dispositivo, conocer la dirección física de nivel 2 (MAC) de otro ordenador o dispositivo con el que quiere comunicarse en la misma red local. El ordenador origen conoce la IP de destino y hace una petición ARP por la red para que el equipo destino conteste con su dirección MAC, siendo guardada después durante un tiempo en una memoria caché en el ordenador que realiza la consulta.
- El objetivo, como en todos los MITM, es meterse en la comunicación de una víctima con otro destino - como Internet -y de esta forma poder modificar la información, robar credenciales o hacer una denegación de servicio.
- Ataca al protocolo ARP, y el principal problema es que este protocolo, fundamental es cualquier red IPv4 actual, no se diseñó pensando en que nadie falsificaría su información y por tanto podemos decir que funciona en la gran mayoría de redes a las que nos conectamos, a no ser que tengan mecanismos de defensa.

- Para que este ataque tenga éxito, se realiza la falsificación de la dirección MAC de ambas partes mediante el protocolo ARP, para de esta forma recibir el tráfico de la víctima y del destino. Es habitual falsificar la dirección MAC del router para la víctima y la dirección de la víctima para el router. De esta forma, la víctima piensa que el router es el equipo del atacante (su dirección MAC) y el router piensa que la víctima es el equipo del atacante, de esta forma se captura el tráfico en ambas direcciones: de la víctima a Internet y de Internet a la víctima



- **Herramientas para ARP spoofing** → arpspoof, ettercap, Caín & Abel, etc.
- **Contramedidas:**
 - **Entradas ARP estáticas**
 - **Inspección ARP en conmutadores /AP:** esta es una de las mejores soluciones pero necesitamos conmutadores o puntos de acceso que soporten estas tecnologías como Cisco DAI, D-Link ARP spoofing prevention, arp-patrol ...Lo que hacen es monitorizar el protocolo ARP y rechazar las tramas maliciosas
 - **Monitorización pasiva** con herramientas como detectores de intrusos, arpwatch, arpalert...

- 
- **Monitorización activa** con herramientas como Marmita, Xarp, Patriot-NG, ettercap ...
 - **Aislamiento de clientes** en puntos de acceso wifi: los puntos de acceso tienen que soportar esta función, pero además del ataque evitan la comunicación directa entre ordenadores en la red wifi, lo cual puede ser una funcionalidad requerida.
 - **Secure ARP - MACSec (802.1AE)**: es un estándar de firma digital similar a IPSec que se está usando en los servidores de Data Centers. Todas las tramas ethernet van firmadas de forma que no es posible suplantar la MAC de nadie.

Ataques al DHCP

- **DHCP Starvation o agotamiento DHCP**
 - Es un ataque que persigue agotar todo el rango de direcciones IP asignables por el servidor de forma que éste deje de servir direcciones y por tanto no contesta a las peticiones de asignación. → Es una denegación de servicio (DoS) al DHCP.
 - El ataque consiste en realizar sucesivas peticiones con direcciones MAC falseadas desde el ordenador del atacante, de forma que el servidor asigna todas las direcciones IP disponibles y se agota el rango.

Ataques al DHCP

- **Rogue DHCP o falso DHCP**
 - Consiste en montar un servidor DHCP no autorizado en la red. Su objetivo es modificar la configuración IP de los equipos de la red. Principalmente se cambia la puerta de enlace y los servidores DNS para que apunten al atacante, con lo que se consigue hacer MITM y DNS Spoofing.
 - Con este ataque podemos asignar puertas de enlace inexistentes provocando un DoS o lo que es peor, asignar como puerta de enlace el ordenador del atacante que funciona como un router. De esta forma todo el tráfico pasa por él, pudiendo capturarlo o modificarlo.
 - El ataque Rogue DHCP se suele realizar después de un DHCP Starvation, para asegurarse de que el servidor DHCP legítimo no funciona al tener agotado el rango.

Ataques al DHCP

- **DHCP ACK Injection**

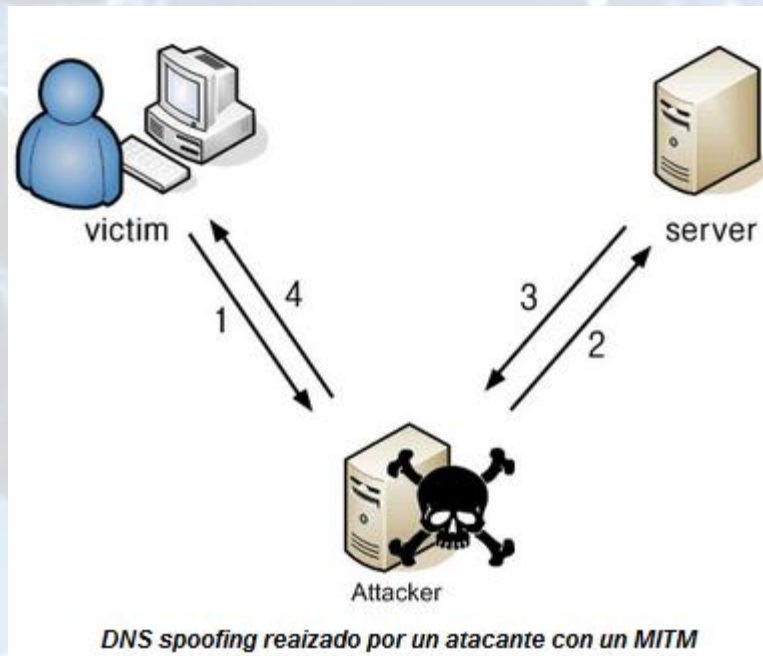
- En vez de montar un servidor DHCP falso, se realiza un seguimiento de las peticiones DHCP (DHCP Request) de los clientes de la red y se contesta con una confirmación (DHCP ACK) con los parámetros de configuración (gateway, dns, etc.) manipulados.
- Sin embargo la respuesta ACK del servidor legítimo podría llegar antes que la del atacante por tanto es un ataque no tiene un 100% de fiabilidad desde el punto de vista del atacante.

Contramedidas

- **Habilitar port-security** en los puertos del switch: esta técnica permite asociar una MAC o un grupo de MAC conocidas, de forma que ante un intento de falsificar la MAC para solicitar una nueva dirección IP, se bloquea el puerto.
- **Habilitar protección DHCP** en los conmutadores y routers.
 - Cisco: DHCP Snooping
 - D-Link: DHCP Server Screening
- **Monitorización activa:** detectar y alertar ante un servidor DHCP no autorizado con herramientas software como dhcp_probe, que es una herramienta para GNU/Linux que puede instalarse en un servidor de la red y nos avisa cuando aparece un servidor DHCP no legítimo.

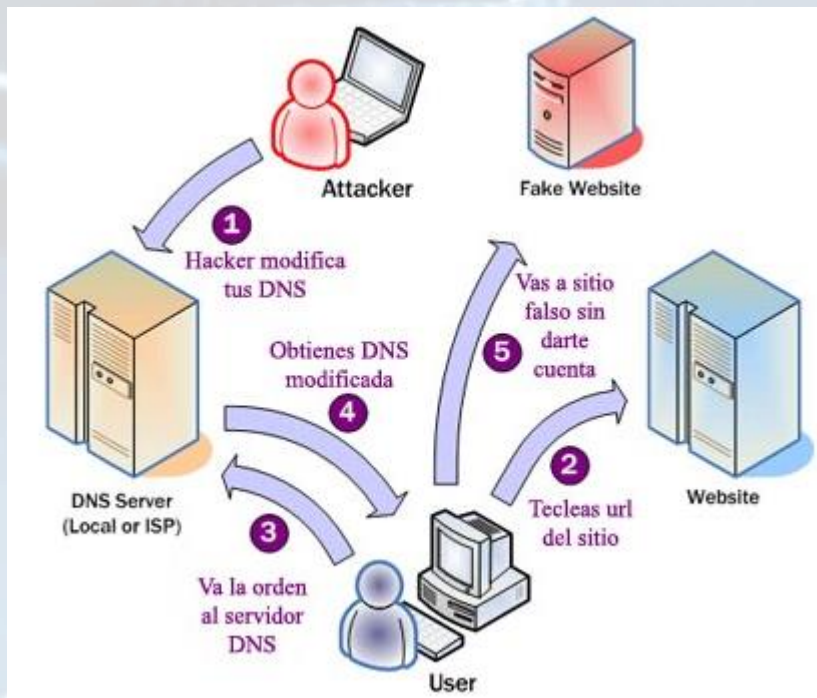
Ataques al DNS

- DNS Spoofing → Técnica que permite manipular las respuestas de un servidor DNS legítimo, mediante un ataque MITM previo para dirigir el tráfico DNS de la víctima hacia el atacante. La forma de evitarlo es mediante las contramedidas de MITM explicadas anteriormente.



Ataques al DNS

- DNS Poison → Es un ataque mucho más peligroso ya que el ataque se realiza contra los servidores DNS que tenemos configurados en nuestro ordenador o dispositivos, de forma que no podemos saber si no podemos controlar o evitar el ataque.



Cuando hacemos la consulta al servidor DNS que ha sido atacado nos puede proporcionar la información que ha introducido el atacante en la caché del servidor DNS.

Es fundamental que los administradores de los servidores DNS estén atentos a cualquier vulnerabilidad asociada al DNS.

Ataque a SSL/TLS

- SSL (Secure Socket Layer)/TLS (Transport Layer Security) son una serie de protocolos que permiten dar seguridad a los protocolos de capa de aplicación que no la poseen de forma nativa, protegiendo de esta manera servicios como las aplicaciones web, el correo electrónico, la transferencia de archivos o la voz sobre IP.
- De esta forma, protocolos como HTTP, SMTP/POP3 o FTP pasan a denominarse HTTPS, SMTPS, POP3S o FTPS cuando usan SSL/TLS por debajo.
- SSL/TLS ofrece cifrado híbrido al combinar algoritmos de clave pública con algoritmos de clave simétrica. La clave simétrica se usa para cifrar las comunicaciones entre ambos extremos, y para intercambiarse dicha clave de sesión, se usa la criptografía de clave pública.

Vulnerabilidades y ataques a SSL/TLS/HTTPS

- **BEAST**: Browser Exploit Against SSL/TLS.
- **Heartbleed** es una vulnerabilidad de OpenSSL
- **Poodle** (Padding Oracle On Downgraded Legacy Encryption)
- **FREAK** (Factoring RSA Export Keys)
- **SSL Strip**
- **Web MITM**
- **Domain Fronting**

Monitorización

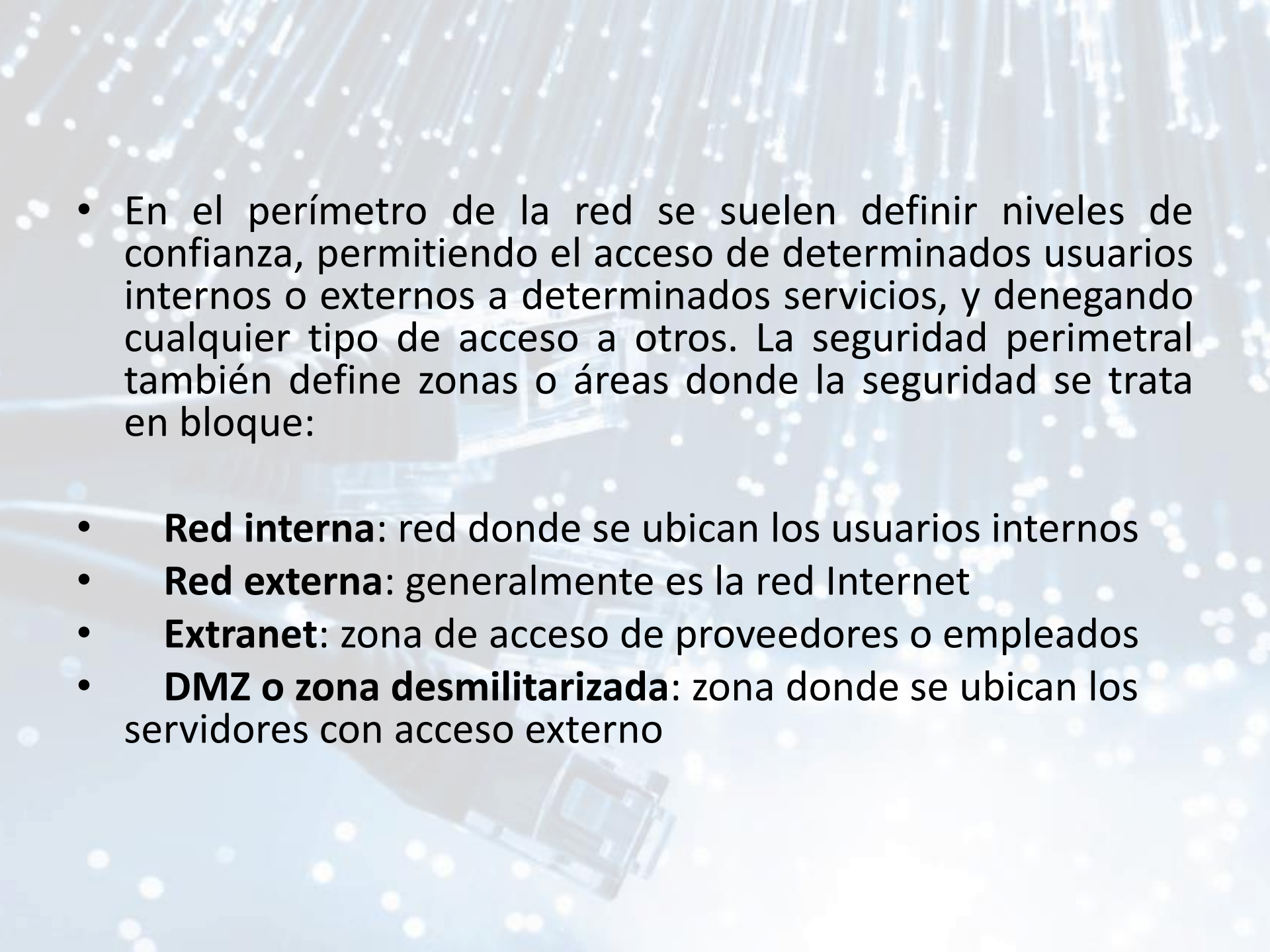
- Las redes informáticas constituyen un entorno dinámico con cambios continuos en el que los usuarios están continuamente navegando por Internet, descargando ficheros de otros equipos, enviando mensajes de correo electrónico, accediendo a otros equipos, etc.
- Con el paso del tiempo su rendimiento puede ser menor y presentar riesgos de seguridad para los equipos debido a:
 - algún malware que genera tráfico en la red
 - un aumento en el tráfico por el número de usuarios o la utilización de nuevas aplicaciones
 - interferencias electromagnéticas
 - desgaste por uso del hardware de red: tarjetas, cableado, equipos...
- Se hace necesario monitorizar y evaluar el rendimiento de la red a lo largo de su vida.
- Para analizar el tráfico que circula por la red se suele enviar una copia de todo el tráfico que circula por la misma a una herramienta de monitorización

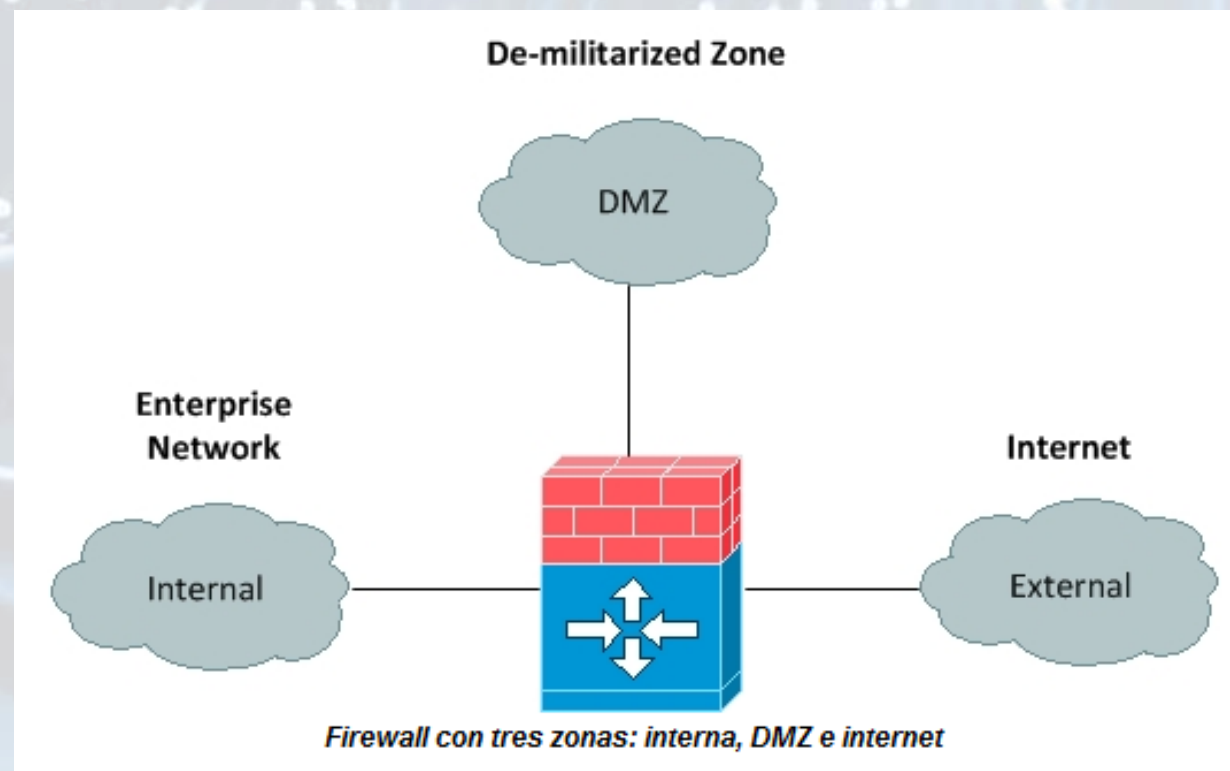
Herramientas de monitorización

- Existen en el mercado muchas herramientas diseñadas para analizar y monitorizar una red, tanto comerciales como Open Source.
- Sus funciones son similares: generación de mapas de red automáticos, elaboración de informes con estadísticas, envío de alertas por email y/o sms, etc.
- Ejemplo: Wireshark, Ettercap, Ntop, HP Openview, MRTG, Cacti, Nagios, PandoraFMS, Ganglia, Zabbix....

Seguridad perimetral

- Por **seguridad perimetral** entendemos el conjunto de métodos y técnicas para proteger una red informática y que se basan en el establecimiento de recursos de seguridad en el perímetro externo de la red y en diferentes niveles.
- El **perímetro de una red** corporativa son los límites entre la red de la organización y las redes a las que ella se interconecta, como por ejemplo Internet. El perímetro de la red es la primera zona a proteger debido a la posibilidad de ataques desde las redes externas a la organización, No obstante, muchos ataques provienen de usuarios internos y hay que proteger la red también de estos ataques.

- 
- En el perímetro de la red se suelen definir niveles de confianza, permitiendo el acceso de determinados usuarios internos o externos a determinados servicios, y denegando cualquier tipo de acceso a otros. La seguridad perimetral también define zonas o áreas donde la seguridad se trata en bloque:
 - **Red interna:** red donde se ubican los usuarios internos
 - **Red externa:** generalmente es la red Internet
 - **Extranet:** zona de acceso de proveedores o empleados
 - **DMZ o zona desmilitarizada:** zona donde se ubican los servidores con acceso externo



Cortafuegos o firewalls

- **Un cortafuegos o firewall** es un dispositivo software o hardware que forma parte de un sistema o red y que está diseñado para proteger dicho sistema o red bloqueando los accesos no autorizados y permitiendo sólo los autorizados, cumpliendo con las directrices definidas en la política de seguridad de la organización.
- Pueden ser implementados en hardware, software o una combinación de ambos.
- **Todo** el tráfico que entra o salga de la red pasa a través del cortafuegos, que lo examina y bloquea aquél tráfico que no cumple los criterios de seguridad especificados en la política.
- Un cortafuegos en el perímetro no es suficiente, es conveniente combinarlo con otros sistemas como los detectores de intrusos (IDS/IPS) o los dispositivos de gestión unificada de amenazas (UTM)

Políticas de acceso en cortafuegos

- Hay dos políticas básicas en la configuración de un cortafuegos:
 - **Política restrictiva:** Se deniega todo el tráfico excepto el que está explícitamente permitido. Por tanto hay que habilitar expresamente el tráfico de los servicios que se necesiten.
 - La restrictiva es la más segura, ya que es más difícil permitir por error tráfico potencialmente peligroso pero a la vez es la que más problemas y más carga administrativa puede exigir al administrador
 - **Política permisiva:** Se permite todo el tráfico excepto el que esté explícitamente denegado. Cada servicio potencialmente peligroso necesitará ser aislado básicamente caso por caso, mientras que el resto del tráfico no será filtrado
 - La política permisiva es menos segura ya que es posible que no se haya contemplado algún caso de tráfico peligroso y sea permitido por omisión.

Tipos de cortafuegos

- **Cortafuegos personales:** son cortafuegos generalmente software que se instalan en una máquina con el fin de protegerla a ella exclusivamente. Son típicos en entornos domésticos y también en entornos empresariales, sobre todo en los servidores ubicados en la DMZ, para “endurecer” todavía más su seguridad. Un ejemplo es el firewall que viene de serie con los sistemas Windows y también iptables en los sistemas GNU/Linux. También hay firewalls de terceros como Zone Alarm o Comodo Pro.
- **Cortafuegos perimetrales:** Son los cortafuegos más habituales en entornos empresariales. Se ubican en el perímetro de la red, esto es, la frontera entre la red interna y la red externa o Internet. Es muy común instalar cortafuegos hardware o dedicados como los ASA o PIX de Cisco Systems, aunque también se usan mucho los cortafuegos por software. Por razones de seguridad, es conveniente que sean equipos dedicados para esa función y con un S.O. propietario que no sea muy conocido para evitar vulnerabilidades de los S.O. más extendidos.

- En función de la capa del modelo OSI en que actúan pueden ser:
- **De filtrado de paquetes:** También llamados **cortafuegos sin estado**, filtran el tráfico mirando únicamente direcciones IP de origen y destino, puertos TCP/UDP origen y destino o protocolo usado, pero sin llevar un seguimiento de conexiones o si forman parte de una secuencia anterior (estado). Funcionan a nivel de red y transporte (capas 3 y 4 del modelo OSI) como filtro de paquetes IP. A menudo en este tipo de cortafuegos se permiten filtrados según campos de nivel de enlace de datos como la dirección MAC.
- **De aplicación:** También llamados **pasarelas de nivel de aplicación o proxys de aplicación**. Actúan sobre la capa de aplicación del modelo OSI. Entienden las aplicaciones y protocolos para los que están diseñados (por ejemplo: FTP, DNS o HTTP) y permiten detectar si un protocolo no deseado se coló a través de un puerto no estándar o si se está abusando de un protocolo de forma perjudicial..
- **De estado o de estado de paquetes:** Permite llevar un seguimiento de cada paquete individual y asignarlo a una sesión o conexión previa. Mantiene registros de todas las conexiones que pasan por el cortafuegos, siendo capaz de determinar si un paquete indica el inicio de una nueva conexión, es parte de una conexión existente, o es un paquete erróneo. También se conoce como **seguimiento de conexiones (connection tracking)**. Este tipo de cortafuegos puede ayudar a prevenir ataques contra conexiones en curso o ciertos ataques de denegación de servicio. Iptables/Netfilter es un ejemplo de cortafuegos de estado.

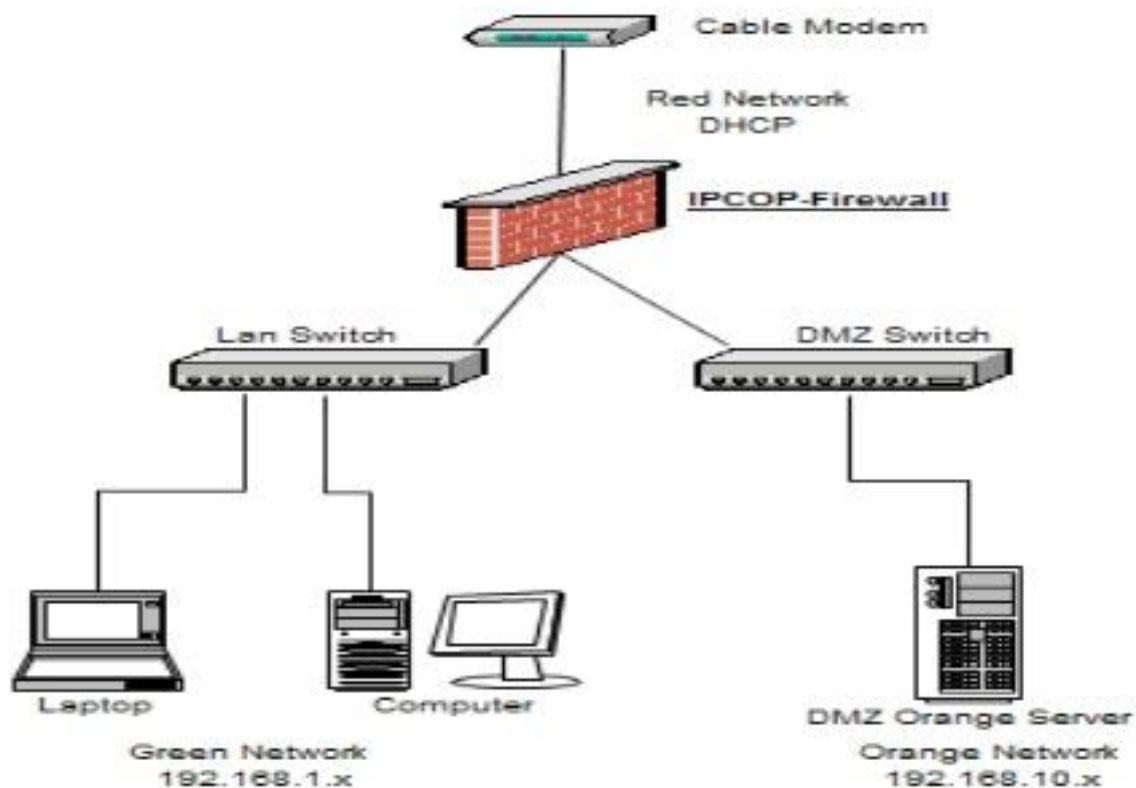
Zonas desmilitarizadas (DMZ)

- Una zona desmilitarizada o DMZ o red perimetral **es una red que actúa como intermediaria entre la red interna de una empresa y la red externa (Internet).**
- La red interna y la externa pueden establecer conexiones con la DMZ, pero desde la DMZ solo se permite establecer conexiones con la red externa, denegando conexiones de entrada a la red interna.
- **El objetivo de una DMZ es que las conexiones desde la red interna y la externa a la DMZ estén permitidas, mientras que en general las conexiones desde la DMZ solo se permitan a la red externa.** Los equipos (hosts) en la DMZ no pueden conectar con la red interna.
- La DMZ se usa habitualmente para ubicar servidores que es necesario que sean accedidos desde fuera, como servidores de correo electrónico, Web y DNS. Estos servicios alojados en estos servidores son los únicos que pueden establecer tráfico de datos entre el DMZ y la red interna, por ejemplo, una conexión de datos entre el servidor web y una base de datos protegida situada en la red interna.
- Las conexiones que se realizan desde la red externa hacia la DMZ se controlan generalmente utilizando port address translation (PAT)

ZONAS DMZ

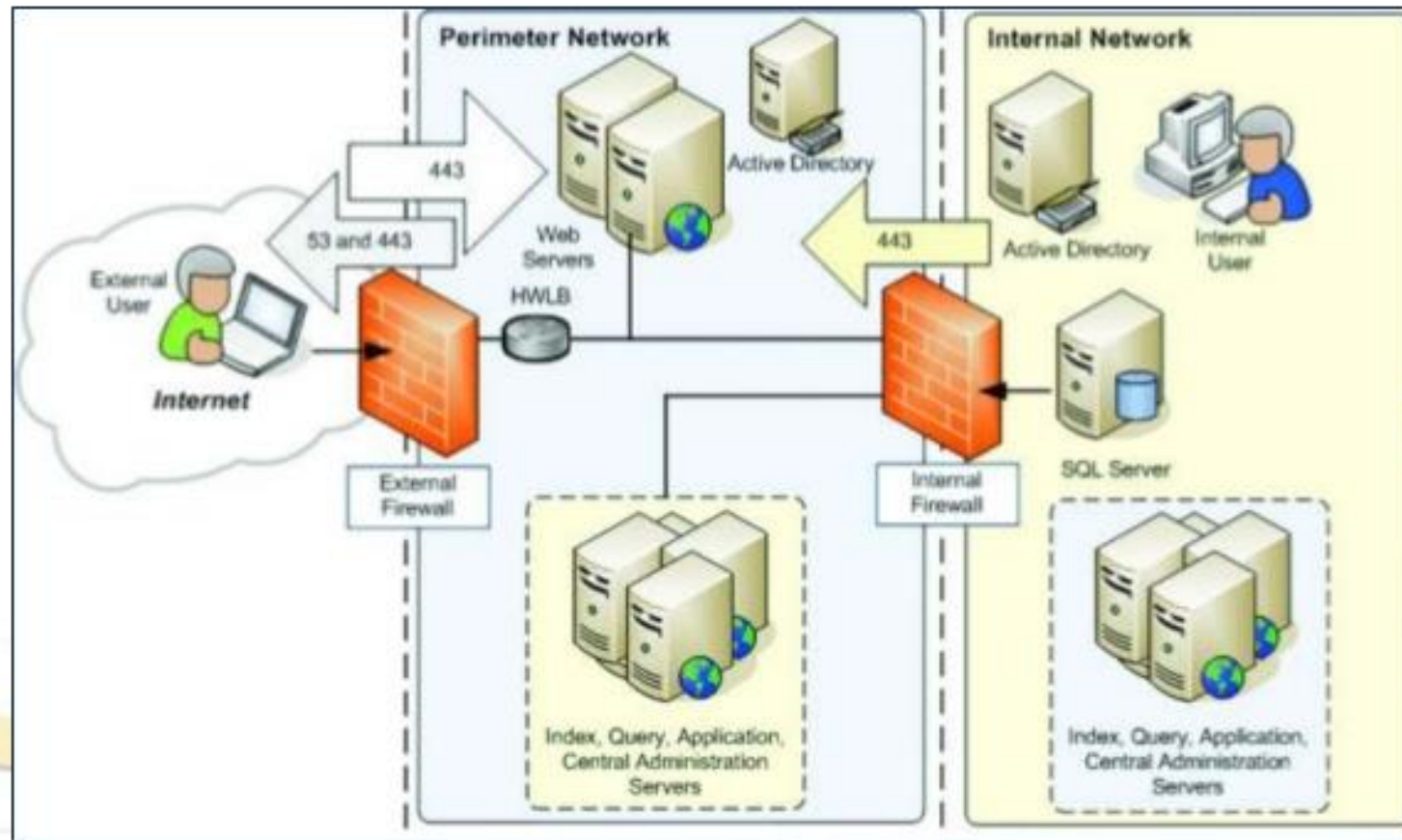
Ejemplo de DMZ en un Firewall IPCOP de tres puertas

Example IPCop Network



ZONAS DMZ

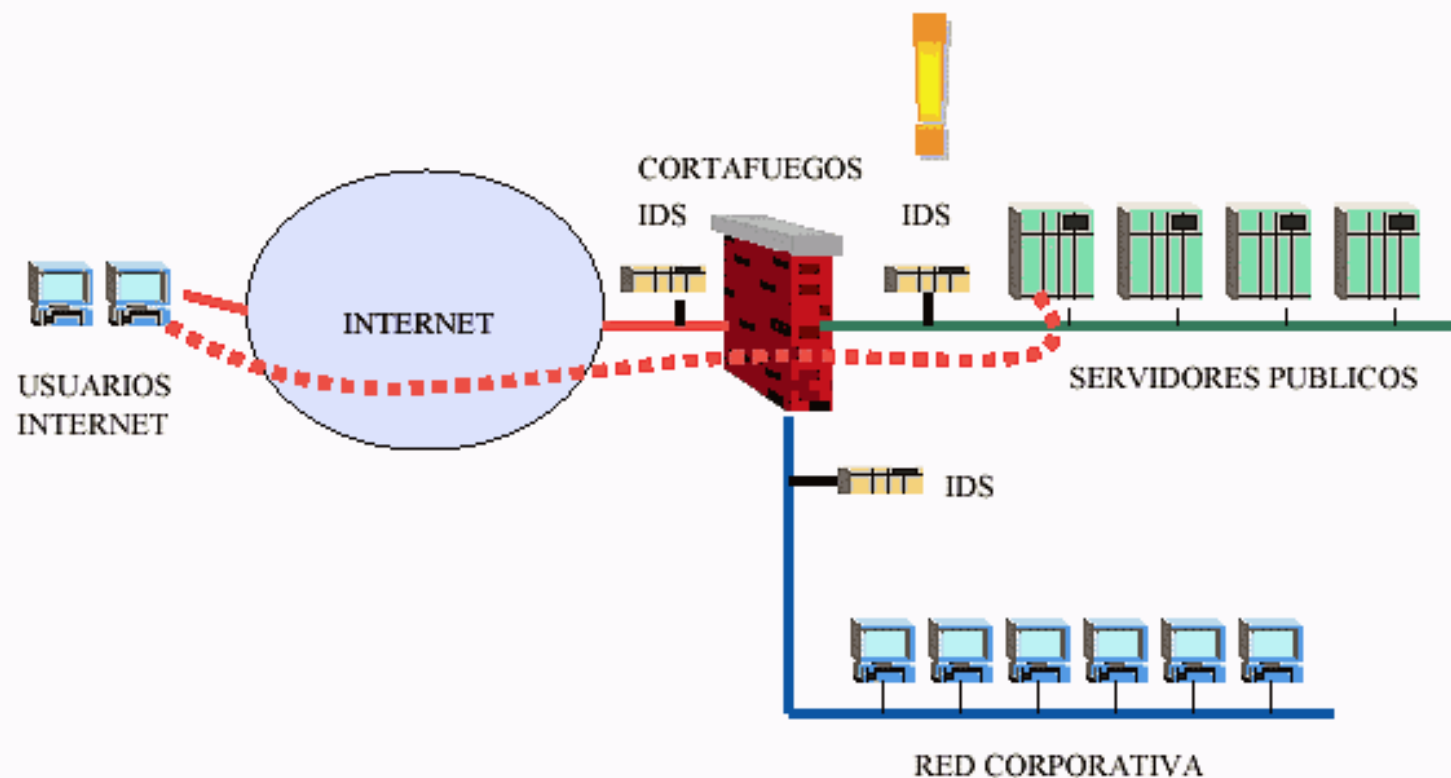
Ejemplo de DMZ con dos firewalls



Detectores de intrusos

- **Sistemas formados por un dispositivo o software que monitoriza, alerta y/o elimina ataques a la red o a los equipos informáticos.**
- Dentro de este tipo de técnicas distinguimos entre:
 - **Sistemas detectores de intrusos**, o IDS (Intrusion Detection System), son un elemento pasivo que detecta ataques pero no los elimina. Distinguimos tres tipos de IDS:
 - HIDS (Host IDS), que monitoriza y protege un equipo.
 - NIDS (Network IDS), que monitoriza y protege una red.
 - DIDS (Distributed IDS), donde se dispone de NIDS distribuidos y gestionados por una consola.
 - **Sistemas de prevención de intrusos** o IPS (Intrusion Prevention System, son un elemento activo que trata de neutralizar el ataque, adaptándose a él. Suelen estar formados por un IDS y un cortafuegos que modifica sus reglas dinámicamente para evitar accesos no autorizados a la red.
- Ejemplo SNORT (pasivo), SURICATA (pasivo), OSSEC (activo), KISMET (pasivo)

Detectores de Intrusismo



Proxies

- Un proxy es un **servicio que realiza la función de intermediario entre él y los clientes que solicitan un determinado servicio**, como por ejemplo HTTP. Trabaja en el nivel de aplicación de OSI.
- El uso más habitual de un servidor proxy es permitir o denegar el acceso a Internet a los equipos de una organización , proporcionando una capa adicional de seguridad.
- Algunas de las **ventajas** de usar un proxy son las siguientes:
 - La navegación puede ser más rápida si se usa la caché y esta es suficientemente grande.
 - Proporciona seguridad al proteger a los equipos cliente de la red externa.
 - Posibilita definir filtros de contenidos y listas de control de acceso para permitir a las organizaciones realizar un control del servicio que se está usando.
- Ejemplos: Squid, Jana,

Gestión unificada de amenazas

- Los dispositivos conocidos como **UTM** (Unified Threat Management) o gestión unificada de amenazas, **combinan distintas técnicas de protección** de redes como cortafuegos, antivirus, antispam, filtro de contenidos, detección y prevención de intrusos redes privadas virtuales y servidor proxy, todo ello **en un único aparato**.
- Son la tendencia actual, sobre todo en pequeñas empresas, donde el ahorro de costes es crítico.
- No obstante, hay que tener en cuenta que el hecho de que todos los sistemas de protección estén integrados en un solo dispositivo puede presentar problemas de rendimiento, escalabilidad y disponibilidad.

Protección en redes inalámbricas

- Las redes inalámbricas presentan las ventajas de: flexibilidad, movilidad y facilidad de conexión.
- **Están expuestas a vulnerabilidades que amenazan la disponibilidad, confidencialidad e integridad de la información.**
- Tipos de ataques más comunes:
 - **Ataque de DoS**
 - **Escuchas del tráfico en la red (sniffing)**
 - **Inyección de tráfico en la red**
 - **Conexiones no autorizadas a la red**
 - **Ataques de acceso:**
 - **Desautenticación:** ataque diseñado para obtener un ESSID oculto de una red y capturar mensajes intercambiados para establecer una conexión, obligando a los clientes a reautenticarse
 - **Falsa autenticación:** se utiliza para registrar una dirección MAC de cliente falsa en un punto de acceso inalámbrico



Mecanismos de seguridad utilizados en redes inalámbricas

- **WEP (Wired Equivalent Privacy)**. Utilizado por defecto por muchos puntos de acceso y routers inalámbricos en la actualidad. Presenta graves fallos de seguridad en el mecanismo de cifrado (RC4), con lo que un atacante podría obtener la contraseña muy rápidamente. Se se desaconseja su uso.
- **WPA (Wireless Protected Access)**. Ofrece una mayor protección que WEP, ya que proporciona una versión mejorada de RC4 e incorpora mecanismos de seguridad adicionales, como TKIP, pero se recomienda utilizar WPA2.

- **WPA2.** Se considera **el mecanismo de seguridad más adecuado** para redes inalámbricas y ofrece mecanismos de cifrado robustos (AES, Advanced Encryption Standard). Existen dos tipos de WPA2 (Personal y Enterprise) que se diferencian en los mecanismos de autenticación:
 - **WPA2 Personal o PSK.** Su mecanismo de autenticación es PSK (Pre-Shared Key), en el que la contraseña se comparte entre el punto de acceso y los clientes de la red. **Es la opción recomendada para redes domésticas.**
 - **WPA2 Enterprise.** Proporciona una mayor flexibilidad para gestionar los mecanismos de autenticación, pudiendo utilizarse un servidor de contraseñas aleatorias (servidor RADIUS) o diferentes tipos de protocolos EAP como usuario y contraseña, certificados digitales, tarjetas inteligentes (smartcards), etc. **Es la opción recomendada para empresas**

- Existen otras medidas que, en algunos casos, complican la gestión de la red o disminuyen el nivel de seguridad, por lo que pueden ser consideradas como falsas medidas de seguridad y se desaconseja su uso:
 - **Filtrado de direcciones MAC.** Esta medida crea una falsa sensación de seguridad, ya que puede ser fácilmente burlada mediante programas que cambien la dirección MAC del atacante.
 - **Ocultación del SSID.** El problema de esta medida es que en este tipo de redes si los puntos de acceso no difunden el SSID, son las estaciones cliente quienes continuamente envían peticiones preguntando si esa red se encuentra dentro de su alcance. Un atacante podría aprovechar esta situación para suplantar la red y establecer conexiones.

Auditorías de seguridad en redes

Una **auditoría** es el proceso realizado por una persona o equipo de personas, denominados auditores, que pueden ser personal de la propia empresa o de una empresa externa, con el objetivo de **revisar el funcionamiento de una determinada área en la organización** → **Auditoría de seguridad informática**

Los **principales objetivos** de una auditoría de seguridad informática son:

- ✓ Verificar si el sistema de seguridad implantado en la organización cumple correctamente con la finalidad de proteger el sistema informático.
- ✓ Detectar posibles vulnerabilidades y amenazas en el sistema informático.
- ✓ Realizar un informe detallado con los resultados obtenidos y, si fuera necesario, un plan de acciones para mejorar el actual sistema de seguridad

En una auditoría de seguridad es fundamental realizar un correcto **análisis de riesgos** para identificar todos los elementos que componen el sistema informático y valorar el impacto y riesgo de las posibles amenazas.

Fases: de un análisis de riesgos:

- ✓ Inventario y valoración de los activos de la organización.
- ✓ Identificación y valoración de las amenazas y vulnerabilidades en el sistema informático.
- ✓ Definición de sistemas de medición de riesgos.
- ✓ Determinación del impacto y riesgo de un ataque o amenaza.
- ✓ Identificación y evaluación de las medidas de seguridad existentes

Pentest o test de penetración o intrusión → consiste en la aplicación de técnicas para intentar romper los sistemas de seguridad de una organización y obtener acceso no autorizado al sistema informático. Es realizado por los auditores de seguridad autorizados por la empresa después del análisis de vulnerabilidades para determinar la vulnerabilidad del sistema informático de una organización.

Tipos de auditoría de red

- Auditoría de red interna → análisis de riesgos, amenazas, vulnerabilidades e impactos desde dentro de la organización sin tener en cuenta los riesgos y amenazas desde Internet
- Auditoría perimetral y de DMZ → se realiza desde Internet, fuera del perímetro de seguridad de la empresa, con el objetivo de evaluar el grado de protección de la empresa frente a ataques externos
- Test de intrusión → se intenta acceder a los sistemas para comprobar el nivel de resistencia a una intrusión no deseada
- Auditoría de aplicaciones → se testean y evalúan las aplicaciones de la empresa, sin tener en cuenta los servidores, dispositivos de red o sistemas operativos
- Análisis forense → se realiza cuando los sistemas ya han sido atacados y comprometidos. Si los daños han provocado la inoperatividad del sistema, el análisis se denomina análisis post mortem

Herramientas y técnicas para auditorías

- Enumeración de redes: Su objetivo es identificar las redes IP asociadas a una organización y descubrir sus servidores. Ejemplo: whois, DNS
- Rastreo de redes: Su objetivo es obtener información más detallada a partir de la conseguida en la enumeración: barrido de direcciones IP con ICMP, barrido de puertos TCP y UDP, identificación de sistema operativo y aplicaciones. Ejemplo NMAP
- Barrido de puertos: trata de identificar qué puertos TCP y UDP están abiertos en un ordenador.
- Fingerprinting: técnicas que sirven para identificar el sistema operativo y las versiones de las aplicaciones que se están usando en los servidores.

- **Análisis de vulnerabilidades.** El objetivo de esta técnica es detectar debilidades en el sistema informático de la empresa y corregirlas. Para el análisis de vulnerabilidades se pueden utilizar herramientas muy diversas, como por ejemplo, Nessus, OpenVAS, SAINT, GFI LanGuard, Core Impact, Retina, ISS, etc.
- **Tests de penetración.** Los tests de penetración, tests de intrusión o pentests son un método para evaluar la seguridad de un sistema informático simulando un ataque de un usuario malicioso, como un black hacker o cracker. Ejemplos de herramientas son: SAINTexploit, Metasploit Framework, NeXpose.

En Linux existen algunas distribuciones especializadas en auditorías de seguridad en redes que incluyen muchas de las herramientas comentadas en este apartado y además permiten auditar la seguridad de una red inalámbrica. Algunas de estas distribuciones son: Backtrack, Kali, Wifiway, WifiSlax o nUbuntu